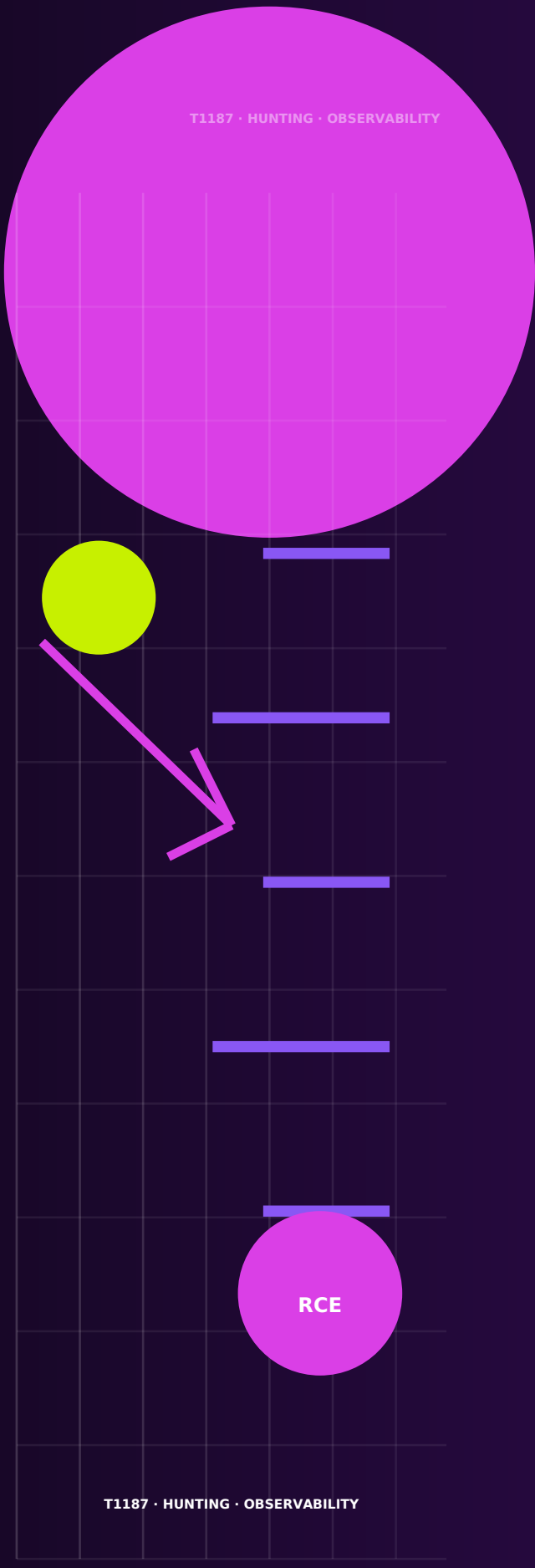
DETECTION THREAT LANDSCAPE

# CVE-2023-23397 - OUTLOOK FORCED NTLM AUTHENTICATION

Hunting query for outlook forced ntlm authentication, with evidence boundaries and target-environment validation requirements




HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
cve

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
9 / 10

01

# Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

**DECISION**

Retain this package as a hunting query and migrate it to the canonical visual and evidence contract without changing query conditions. Treat every result as an investigative lead until local schema, field population, benign overlap and the legacy claim provenance are reviewed.

### LEGACY EVIDENCE RECORD

- The retained legacy source ledger contains 9 normalized references; claim-to-source mapping remains...

### ANALYST ASSESSMENT

- The existing logic is retained at hunting maturity; repository migration is not execution eviden...
- The folder and query header map the package to T1187; operational relevance still depends on local...

### DETECTION ASSUMPTIONS

- The named telemetry is collected across the intended asset or identity scope with adequate...
- Projected fields preserve their expected semantics in the target connector and parser. [C002]
- Approved activity, owners and change records are available to analysts during disposition. [C003]

## KEY FINDINGS

### FINDING 1

The original query conditions and source ledger were preserved during layout migration; legacy PDF SHA-256 98c03dd3862e5c55... is recorded for traceability. [C001]

### FINDING 2

The principal observable is Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while preserving projected investigation context. [C002]

### FINDING 3

The evidence boundary remains explicit: a match does not prove that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use. [C003]

**EVIDENCE BOUNDARY**

A matching result does not prove that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

02

# Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

### TECHNICAL BACKGROUND

The retained dossier links CVE-2023-23397 to the detection opportunity described as outlook forced ntlm authentication. The v2 migration preserves the query exactly and exposes its match boundary, but does not reinterpret legacy source claims as laboratory evidence. Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while preserving projected investigation context. [C001][C002]

1

### THREAT CONTEXT

Hunting query for outlook forced ntlm authentication, with evidence boundaries and target-environment validation requirements Observable: Context retained from the legacy dossier and source ledger.

2

### OBSERVABLE CANDIDATE

Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while preserving projected investigation context. Observable: Events from AlertInfo, DeviceNetworkEvents, DeviceProcessEvents and projected fields.

3

### CONTEXTUAL ENRICHMENT

Resolve asset, identity, process, ownership and change context before disposition. Observable: Raw event, surrounding timeline, inventory and authorized-change evidence.

4

### DECISION GATE

Escalate only when corroborating evidence closes the documented non-claim boundary. Observable: Controlled validation, explainable negatives and analyst-readable evidence.

03

# Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

**PRIMARY PLATFORM**

Microsoft Defender XDR. Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while preserving projected investigation context.

| FIELD / TABLE | STATUS | PURPOSE |
|---|---|---|
| **AlertInfo** | **Required** | Primary event source selected by the unchanged query logic. |
| **DeviceNetworkEvents** | **Required** | Primary event source selected by the unchanged query logic. |
| **DeviceProcessEvents** | **Required** | Primary event source selected by the unchanged query logic. |
| **Event time and entity identifiers** | **Required** | Chronology, deduplication, scoping and investigation pivots. |
| **Raw projected context** | **Required** | Preserve the fields emitted by the query before normalization or tuning. |
| **Asset, identity and change inventory** | **Enrichment** | Separate authorized activity and define operational ownership. |

**KNOWN VISIBILITY GAPS**

Unvalidated local schema Missing projected fields Incomplete retention or asset scope Mutable attacker behavior Legacy claim provenance review pending

04

# Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Rule: [T1187] CVE-2023-23397 - Outlook Forced NTLM Authentication
// MITRE ATT&CK: T1187
// Classification: Hunting query
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR
// Required telemetry: AlertInfo, DeviceNetworkEvents, DeviceProcessEvents
// Purpose: Hunting query for outlook forced ntlm authentication, with evidence boundaries and target-environment validation requirements
// Logic: Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while pres
// A match proves: A native alert, a public SMB attempt or the documented WebDAV pattern should be correlated with mailbox evidence. WHAT IT DOES NOT PROVE It does n
// A match does not prove: that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use.
// Expected false positives: authorized administration, approved software, testing, or benign artifact collisions.
// Coverage limits: local schema, field population, retention, collection scope, and attacker variation require validation.
// Evidence claims: C001, C002, C003
//
// CVE-2023-23397 - Outlook forced NTLM authentication
// Status: Hunting query - Untested implementation sketch
// Confidence: Medium
// Platform: Microsoft Defender XDR Advanced Hunting
// Purpose: expose three independent evidence layers. Results must be correlated
// during investigation; this file does not claim that a network/process match
// alone proves exploitation or credential leakage.

// Query A - product-native CVE-specific alert validation
// Validate whether Defender for Office 365 alert titles use the identifiers
// documented by Microsoft. If no rows are returned, inspect raw AlertInfo titles
// before rejecting coverage.
AlertInfo
| where Timestamp > ago(30d)
| where ServiceSource == "Microsoft Defender for Office 365"
| where Title startswith "Exploit_Office_CVE_2023_23397_"
| project Timestamp, AlertId, Title, Category, Severity,
          ServiceSource, DetectionSource, AttackTechniques
| order by Timestamp desc

// Query B - outbound SMB to public infrastructure
// This detects the network behavior used by the CVE, not the CVE itself.
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort == 445
| where isnotempty(RemoteIP)
| where RemoteIPType == "Public" or not(ipv4_is_private(RemoteIP))
| project Timestamp, DeviceId, DeviceName, ActionType,
          RemoteIP, RemotePort, RemoteUrl, Protocol,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          InitiatingProcessAccountUpn, ReportId
| order by Timestamp desc

// Query C - WebDAV fallback process pattern documented by Microsoft IR
// A match supports an attempted fallback after SMB failure. It does not prove
// that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use.
DeviceProcessEvents
// ... complete 61-line query in hunting.kql
```

### WHAT A MATCH PROVES

A native alert, a public SMB attempt or the documented WebDAV pattern should be correlated with mailbox evidence. WHAT IT DOES NOT PROVE It does not prove a hash was disclosed, relayed or cracked, nor that a user clicked the item.

### WHAT IT DOES NOT PROVE

that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use.

### MATURITY

Hunting query - Untested implementation sketch. Evaluate AlertInfo, DeviceNetworkEvents, DeviceProcessEvents for outlook forced ntlm authentication using the existing source-derived conditions while preserving projected investigation context.

05

# Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

**01**

Preserve the complete raw matching event, query version, timestamp, connector or sensor version and stable entity identifiers.

**02**

Confirm the event originated from the intended Microsoft Defender XDR data source and verify the semantics of every condition used by the query.

**03**

Resolve asset, identity, process, software and destination ownership against authoritative inventories and approved change records.

**04**

Build the surrounding endpoint, identity, network or appliance timeline and seek an independent evidence layer before escalation.

**05**

Classify benign overlap explicitly; tune only with durable ownership or provenance controls, never by suppressing the core behavior globally.

**06**

Escalate only when corroborating evidence establishes malicious or unauthorized activity beyond the documented match boundary.

**DISPOSITION RULE**

Escalate only when the evidence establishes the behavior described by the query. that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use.

06

# False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

### AUTHORIZED ADMINISTRATION OR SOFTWARE

Require owner, purpose, approved change and expected execution or configuration provenance.

### BENIGN ARTIFACT OR COMMAND COLLISION

Require the full condition set plus an independent evidence layer or stable provenance.

### PARSER, INVENTORY OR RETENTION AMBIGUITY

Reproduce a controlled event and reconcile raw fields, collection scope and authoritative inventory.

## VALIDATION SEQUENCE

- Generate an authorized controlled equivalent of the primary observable without using live malicious infrastructure.
- Verify each query condition and projected field against retained raw telemetry.
- Run representative approved and near-match negative controls.
- Measure historical prevalence and classify every returned owner or workflow.
- Record parser, connector, retention and asset-scope dependencies with the test evidence.

### SUCCESS

The controlled positive produces a complete, explainable row and representative negatives are separable through durable context.

### REJECTION

Reject promotion when field semantics, collection scope, benign ownership or the core behavior cannot be established reproducibly.

### PROMOTION GATE

Require claim-level source review, a retained controlled positive, representative negatives, measured prevalence and an accountable operational owner.

07

# Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

## CONCLUSION

This package now uses the canonical v2 layout and evidence contract while preserving the original hunting.kql conditions. It remains a hunting query at medium confidence. The visual migration is complete; claim-level provenance and target-environment execution remain explicit promotion gates.

## MITRE ATT&CK

T1187

## PRIMARY AND AUTHORITATIVE REFERENCES

**S001 Microsoft - Microsoft Incident Response, "Guidance for investigating attacks using CVE-2023-23397", 2023-03-24 (updated 2023-12-04) (2026-07-31)**

hxxps://www[.]microsoft[.]com/en-us/security/blog/2023/03/24/guidance-for-investigating-attacks-using-cve-2023-23397/

**S002 Microsoft - Microsoft Security Response Center, "CVE-2023-23397 Microsoft Outlook Elevation of Privilege Vulnerability", 2023-03-14 (2026-07-31)**

hxxps://msrc[.]microsoft[.]com/update-guide/vulnerability/CVE-2023-23397

**S003 microsoft.github.io - Microsoft CSS-Exchange, "CVE-2023-23397 Exchange scanning script and guidance (2023-03-14)**

hxxps://microsoft[.]github[.]io/CSS-Exchange/Security/CVE-2023-23397/

**S004 cisa.gov - CISA, Known Exploited Vulnerabilities Catalog entry for CVE-2023-23397, added 2023-03-14; remediation due 2023-04-04 (2023-03-14)**

hxxps://www[.]cisa[.]gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2023-23397

**S005 trustedsec.com - TrustedSec, "Critical Outlook Vulnerability: In-Depth Technical Analysis and Recommendations (CVE-2023-23397)", 2023-03-17 (2023-03-14)**

hxxps://trustedsec[.]com/blog/critical-outlook-vulnerability-in-depth-technical-analysis-and-recommendations-cve-2023-23397

**S006 Microsoft Learn - Microsoft Learn, "AlertInfo table in the advanced hunting schema", last reviewed 2026-06-14 (2023-03-17)**

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-alertinfo-table

## OPEN QUESTIONS

A matching result does not prove that Net-NTLMv2 material was leaked and can also result from other UNC/WebDAV use. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

## DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required